

QF Task List

April 23, 2026

1 Risk notes: DIG and YTD

1.1 Episodes and Risk framework milestones

for each episode, which can be anticipated/detected/reacted upon via DIG/YTD?
how would a risk harness detect or mitigate or miss it?

1.1.1 recent (> Oct 2026) real incidents

KelpDAO's rsETH bridge (200M), Drift's, USR depeg (stolen private key, mega mint, no cap), etc

Stream Finance (Nov 2025): xUSD (Stream)/deUSD(Elixir) joint amplification and depeg; every pathology in one episode.

Moonwell (Feb 2026) is the cleanest oracle-wiring case.

KelpDAO (Apr 2026) is the cleanest looping-contagion case.

- get back Amaury's list incidents in his slides

- pipe codex search into DIG and YTD (not sure what I meant here ...)

NB: YTD edges (in the vault unfolding of Amaury) are actually USDC verbs, so should be in the DIG

About the DIG/YTD tool: There is a quadruple root of lender and borrower's illusion (despite the compartmentalisation of markets on some lending platforms)

- collateral independence illusion (depegs propagate through YTD, diagram1): vault can lend on market M_1 :siUSD/USDC where the (staked form of) vault token siUSD/ ∞ FI contains wsrUSD/Reservoir (another staked form of vault

token) in its YTD; depegs on the latter will depeg the former; hence the default probabilities of the former does depend on that of the latter

- TVL illusion (diagram2)
- diversification illusion (diagram2)
- (non-) leverage illusion (dark loops, diagram3): see wash-lending; looping via a vault distorts the leverage of one passive player by the looping one - the increased risk is not visible at the investment surface

2 Allocator

2.1 Lender's allocation

- (done) connect lender's allocator to actual vaults (or set of markets); starting with Amaury's;
 - add in- and out- flows
 - add liquidity constraints

2.2 Looper's allocation

- revise the mms scanning tool; make it a series (via Amaury's node)

3 Execution

illusion of TVL and diversification

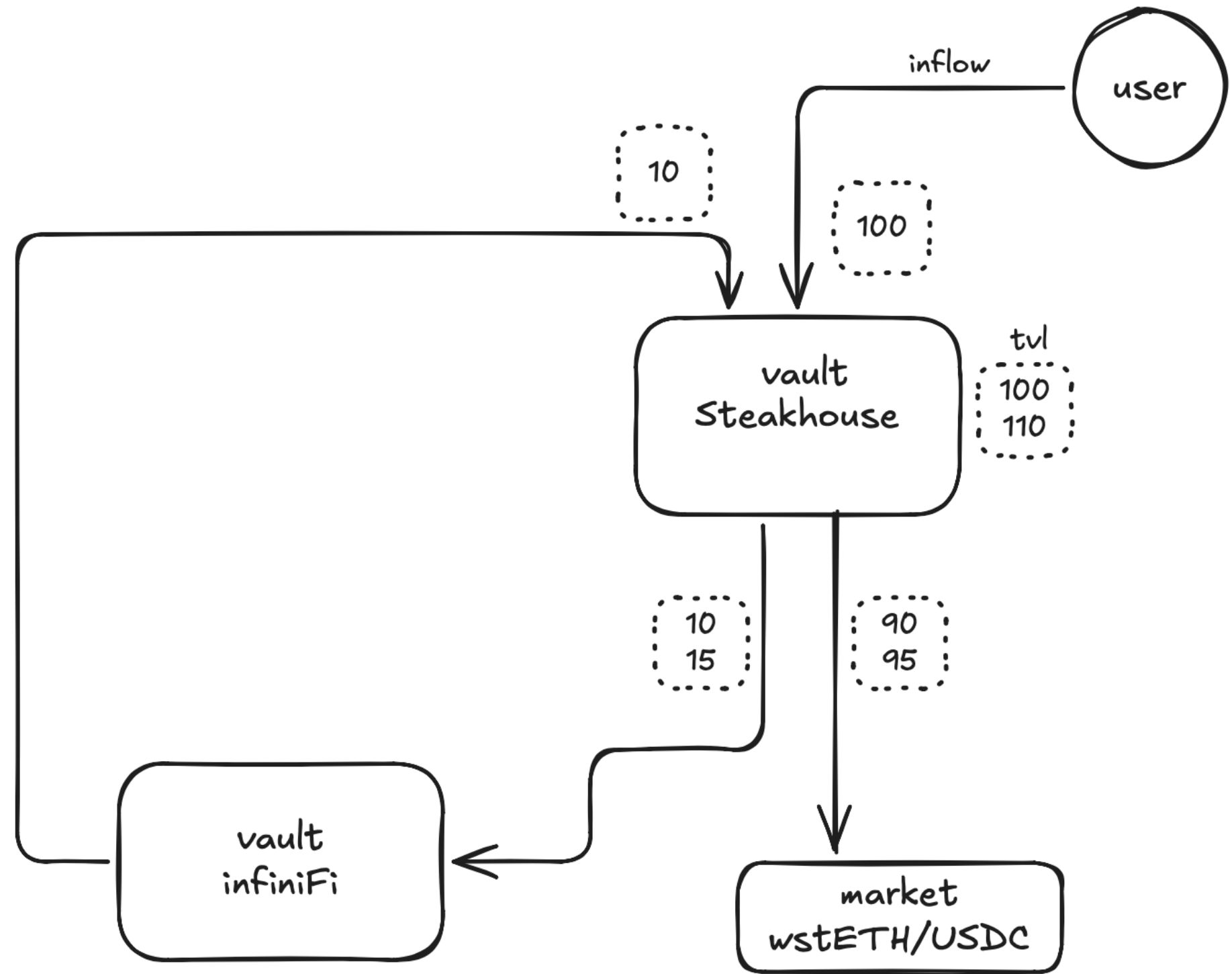


Figure 1: Illusion of TVL and diversification

4 Games

Collect game's views on the 2-sided allocation problem (Morpho v1).

QVI, mean field games etc

A DeFi incidents — October 2025 → April 22, 2026

Compiled from two web-research passes. Uncertainty flags from the underlying agents are preserved. “Verification” entries supersede first-pass claims.

A.1 Verifications (corrections to first-pass claims)

- **Aperture Finance loss: \$3.67M** for Aperture alone. The widely-cited **\$17M** figure is the combined loss across **SwapNet (\$13.43M) + Aperture (\$3.67M)** — same root cause (arbitrary-call + unsanitized `transferFrom` on pre-existing approvals), same day (2026-01-25, ~5:10pm UTC, on Ethereum/Arbitrum/Base/BSC). Treat as two line items or as a joint “SwapNet+Aperture \$17M” incident.
 - **CrossCurve date: 2026-01-31 → 2026-02-01 UTC.** Vector: spoofed Axelar messages via unvalidated `expressExecute` in ReceiverAxelar.
 - **IoTeX (ioTube) date: 2026-02-21.** Compromised Ethereum-side Validator key → TokenSafe drained (\$4.3M USDC/USDT/IOTX/WBTC/BUSD) + 111M CIOTX + 9.3M CCS minted; PeckShield total ~\$8M.
 - **“Morpho TVL \$10B→\$7B tied to Resolv”: claim is mis-attributed.** The \$10B→\$6B figure (Chorus One) describes **risk-curator-managed TVL across DeFi**, and the contraction is dominantly **Nov 2025 Stream-driven**, not Resolv. Morpho itself had limited direct xUSD exposure (~\$68M Plume private + \$628K Arbitrum public). Resolv hit ~15 Morpho vaults; Gauntlet’s USDC Core was the most concentrated (\$4.95M in wstUSR/USDC = 98% of that market’s lender liquidity). MORPHO token fell 4.6% on Resolv, not 30%.
 - **MakinaFi root cause: permissionless oracle manipulation**, not just “MEV builder.” `updateTotalAum()` was public, pulled live Curve spot without TWAP/circuit breaker, and could be moved within the same tx. Flow: flash-loan \$280M USDC (Morpho + Aave) → dump into Curve → call `updateTotalAum()` → withdraw DUSD at inflated NAV → repay. Cantina audit competition had this exact attack class explicitly out-of-scope.
-

A.2 April 2026

A.2.1 KelpDAO (rsETH bridge) — 2026-04-18 — ~\$292M

Single-verifier LayerZero DVN (1-of-1, against LayerZero’s own checklist) let attackers forge a cross-chain message and mint 116,500 rsETH directly. Funds looped through Aave/Morpho/Fluid across 20 chains; Aave left with \$124–\$230M potential bad debt; Morpho ~\$1M in two isolated markets; DeFi TVL fell ~\$13B in 48h. LayerZero/TRM attributed to Lazarus / TraderTraitor (DPRK). **Textbook systemic contagion from a single collateral-side failure amplified by looping.**

- <https://www.coindesk.com/business/2026/04/19/the-usd292-million-kelp-exploit-how-it-happened-and-what-it-means-for-defi>

- <https://thedefiant.io/news/defi/aave-price-crash-kelpdao-exploit-whale-dump-rxi8o9>
- <https://www.coindesk.com/tech/2026/04/20/layerzero-blames-kelp-s-setup-for-usd290-million-exploit-attributes-it-to-north-korea-s-lazarus>

A.2.2 Rhea Finance (NEAR) — 2026-04-15 → 04-17 — ~\$18.4M

Two-day setup: 423 wallets, 8 fake Ref Finance pools, a swap router wiring the fake pools into Rhea’s margin feature → borrow real assets against phantom collateral. Initial \$7.6M reports revised to \$18.4M in postmortem. Some funds returned; Tether froze \$3.29M and \$1.05M frozen in NEAR Intents.

- <https://www.halborn.com/blog/post/explained-the-rhea-finance-hack-april-2026>
- <https://coinedition.com/18-4m-rhea-finance-hack-built-over-two-days-post-mortem-reveals/>

A.2.3 Grinex exchange — 2026-04-15 — ~\$13.7M

Sanctioned Kyrgyzstan/Russia-linked exchange; wallet drain self-framed as “Western intelligence.” Ops suspended. Adjacent to the DeFi April wave but CeFi-side.

- <https://www.coindesk.com/business/2026/04/17/russia-linked-grinex-exchange-halts-operations-after-usd13-million-state-backed-hack>
- <https://thehackernews.com/2026/04/1374m-hack-shuts-down-sanctioned-grinex.html>

A.2.4 Zerion — 2026-04-14 — ~\$100K

AI-assisted NK social engineering (UNC1069) against a Zerion employee; hot-wallet drain, no user funds. Second major NK AI-SE campaign in April after Drift.

- <https://cointelegraph.com/news/north-korean-hackers-use-ai-enabled-social-engineering-latest-attack>

A.2.5 CoW Swap (cow.fi DNS hijack) — 2026-04-14 — ~\$1.2M

Forged identity docs against Finland’s Traficom registry + Gandi SAS registrar pointed swap.cow.fi to a phishing site for hours. Protocol contracts untouched; losses are pure wallet-approval phishing. CoW migrated to cow.finance + RegistryLock. Part of a **.fi**-targeted campaign (Steakhouse, HypurrFi, Neutrl).

- <https://protos.com/cow-swap-hit-by-dns-hijack-warns-users-to-stay-clear-of-site/>
- <https://www.coindesk.com/tech/2026/04/14/popular-defi-platform-warns-users-to-stay-away-from-its-site-after-security-breach>

A.2.6 Hyperbridge (Polkadot ↔ Ethereum gateway) — 2026-04-13 — ~\$2.5M

Missing bounds check in MMR proof verifier → forged cross-chain messages → **1 billion bridged DOT minted** on Ethereum, dumped for ~\$237K ETH initially, total realized loss across Ethereum/Base/BNB/Arbitrum ~\$2.5M. Native DOT unaffected. Marketed as “safest bridge.”

- <https://www.theblock.co/post/397167/bridged-dot-hyperbridge-exploit>
- <https://www.cryptotimes.io/2026/04/16/hyperbridge-raises-exploit-loss-estimate-to-2-5m-from-237k/>

A.2.7 Dango perps DEX — 2026-04-13 — \$410K bridged / \$1.9M at risk (fully recovered)

Insurance-fund donation logic accepted zero-amount donations; attacker manipulated insurance accounting. Rate limits capped bridged-out to \$410K; remainder stuck on Dango’s chain and recovered. White-hat outcome.

- <https://ambcrypto.com/dango-exploit-resolved-after-white-hat-returns-funds-users-unaffected/>

A.2.8 Silo Finance (misconfigured oracle) — 2026-04-03 — \$392K

Small oracle misconfig exploit, part of the post-Drift wave. Not novel but signals curator/parameter mistakes remain live on mature lending protocols.

- <https://blockchain.news/news/12-defi-protocols-hacked-drift-exploit-april-2026>

A.2.9 Drift Protocol (Solana perps) — 2026-04-01 — ~\$285M

Lazarus-attributed multisig compromise: 3–6 weeks of social engineering got Security Council signers to pre-sign transactions wrapped as Solana durable nonces (live-forever authorizations). Wash-traded a fake CVT token to ~\$1; activated pre-signed instructions to list CVT as collateral, raise caps, deposit CVT, drain ~\$285M in ~12 min, bridge to Ethereum. **Attacker-controlled collateral listing is a vault-risk endgame.**

- <https://www.trmlabs.com/resources/blog/north-korean-hackers-attack-drift-protocol-in-285-million-heist>
- <https://blocksec.com/blog/drift-protocol-incident-multisig-governance-compromise-via-durable-nonce-exploitation>
- <https://www.coindesk.com/tech/2026/04/02/how-a-solana-feature-designed-for-convenience-let-an-attacker-drain-usd270-million-from-drift>

A.3 March 2026

A.3.1 Resolv Labs (USR stablecoin) — 2026-03-22 — ~\$25M ETH extracted; 80M unbacked USR minted

Compromised SERVICE_ROLE EOA (not multisig) with mint rights deposited ~\$100–\$200K USDC and minted 80M USR (~500× over-mint). USR fell \$1 → \$0.025 intraday. Triggered liquidations/bad debt across ~15 Morpho vaults (Gauntlet USDC Core was the most concentrated; 98% of wstUSR/USDC market lender liquidity). **Canonical “over-mint → depeg → looping-vault bad debt” case.**

- <https://www.quillaudits.com/blog/hack-analysis/resolv-labs-exploit-explained>
- <https://www.coindesk.com/markets/2026/03/23/resolv-stablecoin-drops-70-after-usd80-million-exploit-after-attacker-mints-usr>
- <https://www.blockaid.io/blog/how-a-compromised-key-minted-80m-in-resolvs-usr-stablecoin-and-triggered-a-depeg>

A.3.2 Cyrus Finance — 2026-03-22 — ~\$5M

Flash-loan pool-share accounting exploit (thin public detail). Same-day as Resolv; grouped in PeckShield’s March “shadow contagion” wave (\$52M total for the month).

- <https://smartcontractshacking.com/hacks/cyrus-finance-hack-2026>
- <https://cryptopotato.com/report-crypto-hacks-rose-96-in-march-as-losses-hit-52m/>

A.3.3 Neutrl — 2026-03-19 — ~zero loss

Part of the .fi DNS campaign. Team paused contracts, migrated domain, switched DNS providers. NAV in custodial wallet; users told to revoke Permit2 approvals.

- <https://www.cryptotimes.io/2026/03/19/neutrl-defi-pauses-smart-contracts-amid-suspected-dns-frontend-hijack/>

A.3.4 Venus Protocol (BNB) — 2026-03-16 — ~\$3.7M extracted / ~\$2.15M protocol bad debt

Nine-month setup: attacker accumulated 84% of Venus’s THE supply cap, used a “donation” to bypass the cap, pumped THE from \$0.27 → ~\$5, borrowed against inflated collateral. **Known Compound-fork vulnerability** previously flagged in audits. Clean illiquid-collateral + market-price-oracle case.

- <https://www.halborn.com/blog/post/explained-the-venus-protocol-hack-march-2026>
- <https://www.theblock.co/post/393622/venus-protocol-left-with-roughly-2m-in-bad-debt-after-exploit-manipulates-thenas-the-token-price>

A.3.5 Aave (wstETH CAPO oracle liquidations) — 2026-03-10 — \$27.78M liquidated (not stolen)

CAPO (Correlated Asset Price Oracle) misconfiguration under-reported wstETH/ETH ratio (~1.19 vs. market 1.23), triggering \$27.78M of borrower liquidations. Chaos Labs attributed it to CAPO rate-limit config, not the feed. Aave DAO fully reimbursed. Noteworthy oracle-parameter incident at the largest lending protocol.

- <https://www.coindesk.com/business/2026/03/10/defi-lending-platform-aave-sees-a-rare-usd27-million-liquidations-after-a-price-glitch>

A.3.6 1inch (Fusion v1 resolver) — 2026-03-05/06 — ~\$5M

Calldata-length / buffer-overflow bug in deprecated Fusion v1 `_settleOrder` let attacker forge resolver addresses and drain TrustedVolumes + other resolvers (~2.4M USDC + 1,276 WETH). End-user funds untouched. Attacker took a bounty; most returned minus ~10% (\$450K).

- <https://olympixai.medium.com/the-1inch-fusion-v1-exploit-how-a-calldata-corruption-vulnerability-drained-5-million-d5667c83fc2a>
- <https://blog.1inch.com/vulnerability-discovered-in-resolver-contract/>
- <https://rekt.news/1inch-rekt>

A.3.7 Solv Protocol — March 2026 — ~\$2.7M (~38 SolvBTC)

Reentrancy / double-mint in a BRO vault handling ERC-3525 deposits; 22 iterations turned ~135 real BRO into ~567M counterfeit BRO. Covered from protocol reserves; 10% bounty offered. Another vault-accounting → synthetic-token over-issuance data point.

- <https://www.ccn.com/education/crypto/defi-hacks-2026-137m-lost-step-finance-truebit-resolv-exploits/>

A.4 February 2026

A.4.1 Foom Cash — 2026-02-26 — \$2.26M (~\$1.84M white-hat recovered)

Groth16 verifier misconfiguration (`delta2 == gamma2`, Phase 2 trusted-setup step skipped in snarkjs) → forged withdraw proofs via arbitrary `nullifierHash` (0xdead0000...0xdead001c ×29+). Ethereum + Base pools drained. Copycat of Veil Cash four days earlier. White-hat (Duha + Decurity) saved 81% on Ethereum; ~\$420K net theft on Base.

- <https://rekt.news/the-unfinished-proof>
- <https://nomoslabs.io/archive/foom-cash-2026>

A.4.2 YieldBlox (Stellar Blend pool) — 2026-02-22 — \$10.2M (~\$7.2M frozen)

Thin-liquidity oracle manipulation on Stellar. Single USTRY/USDC offer at 501 USDC seeded an idle book (MM had withdrawn 15 min prior), inflating the Reflector oracle; attacker borrowed out the entire reserve (61.25M XLM + 1M USDC). Stellar Tier-1 validators froze \$7.2M. **Novel: Stellar/Reflector.**

- <https://www.halborn.com/blog/post/explained-the-yieldblox-hack-february-2026>
- <https://blocksec.com/blog/yieldblox-dao-incident-on-stellar-oracle-misconfiguration-enabled-a-10m-drain>

A.4.3 IoTeX ioTube bridge — 2026-02-21 — ~\$4.3M + 111M CIOTX/9.3M CCS minted (~\$8M PeckShield)

Compromised Ethereum-side Validator private key → arbitrary withdrawals + synthetic mints. Off-chain key-management failure.

- <https://www.cryptotimes.io/2026/02/22/iotex-confirms-4-3m-iotube-bridge-breach-validator-key-compromised/>
- <https://www.halborn.com/blog/post/month-in-review-top-defi-hacks-of-february-2026>

A.4.4 Veil Cash (Base, 0.1 ETH pool) — 2026-02-20/22 — 2.9 ETH (~\$7K)

The zkSNARK-soundness progenitor that Foom Cash copycat'd. Same `delta2 == gamma2` flaw, 29× looping with fake nullifiers. Tiny \$ but analytically important as the trigger pattern.

- <https://coinsbench.com/forging-zksnark-proofs-via-misconfigured-verification-keys-the-veil-01-eth-exploit-2a6bb7d0078b>
- <https://github.com/DK27ss/VeilCash-5K-PoC>

A.4.5 OpenEden (DNS hijack attempt) — 2026-02-16 — no loss reported

AngelFerno wallet-drainer campaign; DNS of main site + user portal compromised. Reserves in custodial wallet; users warned.

- <https://bitcoinethereumnews.com/finance/openeden-users-face-asset-loss-threat-as-dns-attack-hijack-portals/>

A.4.6 Curvance (frontend attack blocked) — 2026-02-16 — zero loss

AngelFerno targeted Curvance's frontend via DNS without DNSSEC; detected by security partners before funds moved. Contract interactions paused.

- <https://cryptorank.io/news/feed/2ea6f-curvance-defi-hack-thwarted-no-loss>

A.4.7 Moonwell (cbETH oracle misconfig) — 2026-02-15 — ~\$1.78M bad debt

MIP-X43 wired the cbETH/USD feed as cbETH/ETH only (no ETH/USD mult) → cbETH priced at ~\$1.12 instead of ~\$2,200. Liquidation bots took 1,096 cbETH in minutes. PR listed Claude Opus 4.6 as co-author, triggering “vibe-coded governance” coverage. **Highly relevant to Morpho-ecosystem risk: same ratio-feed misconfig risk exists in any Blue/MetaMorpho market accepting LSTs via ratio oracles.**

- <https://forum.moonwell.fi/t/mip-x43-cbeth-oracle-incident-summary/2068>
- <https://www.theblock.co/post/390302/defi-lending-protocol-moonwell-hit-with-1-8-million-bad-debt-after-oracle-misconfiguration>
- <https://protos.com/defi-meet-claude-moonwells-vibe-coded-oracle-in-1-8m-blowup/>

A.4.8 CrossCurve — 2026-01-31 → 02-01 — ~\$3M

Spoofed Axelar-style messages exploited unvalidated `expressExecute` in PortalV2’s ReceiverAxelar.

- <https://www.theblock.co/post/387939/crosscurve-bridge-exploited-for-approximately-3-million-across-multiple-chains-via-spoofed-messages>
-

A.5 January 2026

A.5.1 Step Finance (Solana) — disclosed 2026-01-31 — ~\$27.3M (261,854 SOL)

Exec device phished; keys drained the multisig. Not a contract bug. Step wound down. **Reminder: multisig ≠ security when signer endpoints fall.**

- <https://www.coindesk.com/business/2026/02/24/step-finance-shuts-operations-after-usd27-million-january-hack>
- <https://www.halborn.com/blog/post/explained-the-step-finance-hack-january-2026>

A.5.2 SwapNet — 2026-01-25 — ~\$13.43M

Joint-vector exploit with Aperture (same day). Arbitrary-call vulnerability in router/executor abused pre-existing user ERC20 approvals via `transferFrom()`.

- <https://blocksec.com/blog/17m-closed-source-smart-contract-exploit-arbitrary-call-swapnet-aperture>

A.5.3 Aperture Finance — 2026-01-25 — ~\$3.67M

Same root cause as SwapNet; closed-source V3/V4 contracts. ~1,242 ETH (\$2.4M) laundered via Tornado Cash. **Canonical approval-surface + unsanitized external call bug.**

- <https://blog.solidityscan.com/aperture-finance-hack-analysis-22dca439ff33>
- <https://coinpedia.org/news/defi-hack-alert-aperture-finance-smart-contract-exploit-suffers-3-67m-loss/>

A.5.4 Saga (SagaEVM) — 2026-01-21 — ~7.0M *Bridge-validationbypassviaIBCprecompilemanipulation.CustomIBCmessagesintotheprecompilemintedSagaDollar(D)* from thin air; \$D depegged to \$0.75. SagaEVM halted at block 6,593,800; TVL crashed \$37M → \$16M in 24h. Cosmos infra intact.

- <https://www.theblock.co/post/386638/sagaevm-suffers-exploit>
- <https://rekt.news/saga-rekt>

A.5.5 MakinaFi — 2026-01-20 — ~\$4.2M (1,299 ETH)

Permissionless oracle manipulation (not just “MEV builder”). `updateTotalAum()` public + live Curve spot + no TWAP/circuit breaker. Attack: flash-loan \$280M USDC → distort Curve balances → `updateTotalAum()` → withdraw DUSD at inflated NAV → repay. Cantina audit had this class out-of-scope.

- <https://rekt.news/makina-rekt>
- <https://coinalertnews.com/news/2026/01/20/defi-protocol-makinafi-4m-exploit>

A.5.6 Truebit Protocol — 2026-01-08 — ~\$26.44M (8,535 ETH)

Integer overflow in legacy Solidity ^0.6.10 `getPurchasePrice()` (pre-SafeMath). Wrapped price to ~0 → ~ 2.4×10^{26} TRU minted effectively free, dumped for ETH. **Tail risk of “archeological” contracts still holding value.**

- <https://blocksec.com/blog/in-depth-analysis-the-truebit-incident>
- <https://www.dlnews.com/articles/defi/truebit-hit-by-exploit-as-attackers-increasingly-target-older-defi-protocols/>

A.5.7 TMXTribe (GMX fork, Arbitrum) — 2026-01-05 — \$1.4M

Unverified contract, no sanity checks in LP staking/swap. Loop: mint+stake TMX LP with USDT → swap USDT for internal USDG → unstake → dump USDG. Drained over 36h while team deployed new contracts without pausing. No public acknowledgment.

- <https://rekt.news/tmztribe-rekt>
-

A.6 December 2025

A.6.1 Unleash Protocol — 2025-12-30 — ~\$3.9M

Story Protocol-based IP finance. Multisig governance takeover → unauthorized contract upgrade → drained WIP, USDC, WETH, stIP, vIP. 1,337 ETH via Tornado Cash. Story Protocol itself unaffected.

- <https://www.coindesk.com/business/2025/12/30/unleash-protocol-hit-by-usd3-9-million-exploit-with-funds-routed-through-tornado-cash>

A.6.2 Flow blockchain execution-layer exploit — 2025-12-27 — ~\$3.9M

Execution-layer flaw → unauthorized native FLOW + bridged-asset minting. Foundation proposed ~6h chain rollback; blindsided deBridge and others. FLOW -40% on disclosure. **L1-level trust-assumption / rollback-governance precedent.**

- <https://www.theblock.co/post/383808/flows-controversial-planned-rollback-to-undo-3-9-million-exploit-blindsided-some-partners>

A.6.3 Yearn Finance (iEarn TUSD legacy v1) — 2025-12-16 — ~\$290K (103 ETH)

Second Yearn exploit in <3 weeks. Flash-loan share-price manipulation of a legacy v1 vault. Current Yearn vaults unaffected. **Legacy-contract risk remains alive.**

- <https://thedefiant.io/news/defi/yearn-finance-earn-vault-hacked>

A.6.4 Aevo / legacy Ribbon DOV vaults — 2025-12-12 — ~\$2.7M

Dec 6 oracle upgrade allowed arbitrary users to push prices for newly added assets. Attacker loaded manipulated expiry prices for wstETH/AAVE/LINK/WBTC into the shared oracle; drained legacy Ribbon DOV contracts in one atomic loop. Primary Aevo L2 exchange unaffected. Aevo proposed a 19% haircut; vaults sunsetted.

- <https://www.theblock.co/post/382461/aevo-legacy-ribbon-dov-vaults-exploited-for-2-7-million-following-oracle-upgrade>
- <https://rekt.news/aevo-rekt>

A.6.5 USPD stablecoin (CPIMP proxy takeover) — 2025-12-04 — ~\$1M

Clandestine-Proxy-In-the-Middle-of-Proxy. Attacker front-ran proxy init on 2025-09-16 (seized admin within 24s), embedded a shadow implementation that forwarded to the legitimate code — explorers showed the correct implementation. Held admin silently **78 days**. On Dec 4: upgraded proxy to malicious logic, minted 98M USPD, drained 232 stETH. **Novel: deployment-stage, not runtime, vulnerability.**

- <https://crypto.news/uspd-stablecoin-protocol-exploited-proxy-breach-2025/>
- <https://rekt.news/uspd-rekt>

A.6.6 Trust Wallet browser extension v2.68 — December 2025 — >\$6M (exact date imprecise)

Malicious extension distribution exfiltrated keys across BTC/ETH/SOL. Mobile + other extension versions unaffected. CZ said Trust Wallet would cover losses. **Supply-chain / distribution-pipeline risk** — same category as concurrent npm/crypto-drainer disclosures.

- <https://www.ccn.com/education/crypto/trust-wallet-warning-6m-lost-btc-eth-sol-browser-extension/>
-

A.7 November 2025

A.7.1 Yearn Finance (yETH StableSwap pool) — 2025-11-30 — ~\$9M

“16 wei → infinite yETH” bug. Cached `packed_vbs[]` virtual balances desynced from main supply counter. 10+ deposit/withdraw flash-loan cycles left residuals; then withdrew all liquidity (supply → 0 while cache stayed populated); then deposited 16 wei across 8 tokens and minted 235 septillion yETH (41-digit). Drained \$8M+ in one tx; \$3M to Tornado Cash. Yearn’s primary \$410M yield markets unaffected.

- <https://www.dlnews.com/articles/defi/yearn-finance-looted-for-9m-after-attacker-minted-trillions/>
- <https://research.checkpoint.com/2025/16-wei/>

A.7.2 Aerodrome (+ Velodrome) DNS hijack — 2025-11-21/22 — ~\$700K–\$1M+

NameSilo internal compromise bypassed 3DNS multisig, removed DNSSEC, pointed `.box` and `.finance` domains to phishing frontends. Users drained via malicious approvals. Base’s largest DEX.

- <https://www.coindesk.com/web3/2025/11/22/aerodrome-finance-hit-by-front-end-attack-users-urged-to-avoid-main-domain>
- <https://www.halborn.com/blog/post/explained-the-aerodrome-finance-hack-november-2025>

A.7.3 GANA Payment (BSC) — 2025-11-20 — ~\$3.1M

Compromised smart-contract ownership (likely PK theft). Attacker changed reward rates, abused unstake to drain user deposits. 1,140 BNB + 346.8 ETH → Tornado Cash; GANA token -90%. Discovered by ZachXBT.

- <https://www.theblock.co/post/379619/gana-payment-exploit>

A.7.4 Hyperliquid HLP vault (POPCAT manipulation) — 2025-11-13 — ~\$4.9M bad debt

Market-manipulation attack (not a contract exploit). \$3M USDC from OKX across 19 wallets → longs totaling \$20M+ on POPCAT → \$20M buy wall at \$0.21 to pump → wall withdrawn → price crashed. Attacker's \$3M liquidated; HLP community vault absorbed \$4.9M bad debt. \$63M total POPCAT long liquidations in 4h. **Third market-manipulation attack on Hyperliquid in 2025.**

- <https://www.coindesk.com/markets/2025/11/13/peak-degen-warfare-alleged-popcat-manipulation-hits-hyperliquid-with-usd4-9m-loss>

A.7.5 Elixir deUSD / sdeUSD collapse — 2025-11-04 → 11-07 — ~98% drawdown

~65% of deUSD collateral was allocated to Stream Finance via **private Morpho vaults where Stream was the sole borrower using xUSD as collateral**. When Stream collapsed, deUSD fell 98% → ~\$0.03. Elixir announced wind-down; ~80% holders redeemed at par pre-collapse. Morpho delisted sdeUSD/USDC (3.6% bad debt). K3 Capital threatened legal action.

- <https://finance.yahoo.com/news/elixir-shuts-down-deusd-stablecoin-104937488.html>
- <https://coinfo.com/morpho-delists-elixir-sdeusd-bad-debt/>

A.7.6 Stables Labs USDX depeg — 2025-11-04 → 11-07 — to \$0.0644 low (~94% drawdown)

Tangentially triggered by Nov 3 Balancer V2 drain of USDX/sUSDX pool liquidity (~\$1M direct loss); cascaded via Lista DAO + PancakeSwap high-leverage liquidations. Phased recovery plan announced.

- <https://bitcoinethereumnews.com/tech/stable-labs-outlines-phased-usdx-recovery-plan-after-depeg-incident/>

A.7.7 Stream Finance (xUSD) → DeFi contagion — 2025-11-04 — ~\$93M initial fund-mgr loss; ~\$285M interconnected exposure

Off-chain “external fund manager” loss, not a contract bug. xUSD \$1 → \$0.26 (-77%) in 24h; withdrawals suspended. **Multiple lenders had hardcoded xUSD's oracle at \$1 to prevent cascade liquidations — which instead locked the depeg in as bad debt.** Euler: ~\$137M bad debt in third-party-curated vaults. TelosC

(\$123.6M) and Elixir (\$68M) largest direct exposures. **The single most important case in the period for Morpho-ecosystem systemic-risk analysis:** pinned oracles, risk-curator allocation, hidden-borrower private vaults, recursive collateral loops, TVL illusion — all in one episode.

- <https://blockeden.xyz/blog/2025/11/08/m-defi-contagion/>
- <https://protos.com/stream-finance-meltdown-winners-and-losers-in-defi-risk-curator-reckoning/>
- https://x.com/QuillAudits_AI/status/1986377632926273796
- <https://coinfomania.com/morpho-delists-elixir-sdeusd-bad-debt/>

A.7.8 Balancer V2 ComposableStablePool — 2025-11-03 — ~\$120–\$128M (6 chains); ~\$45M recovered

Rounding-direction inconsistency in `_upscaleArray` (always rounds down) vs. bidirectional downscaling, compounded via batchSwap composability. Constructor executed 65+ micro-swaps compounding 1-wei errors into macro-scale invariant violation. V3 + non-stable V2 pools unaffected. Forks (Beets) lost \$3M+ more. Two-stage execution evaded some monitoring.

- <https://research.checkpoint.com/2025/how-an-attacker-drained-128m-from-balancer-through-rounding-error-exploitation/>
 - <https://blocksec.com/blog/in-depth-analysis-the-balancer-v2-exploit>
 - <https://www.openzeppelin.com/news/understanding-the-balancer-v2-exploit>
-

A.8 October 2025

Unusually quiet month per PeckShield/Halborn: 85.7% MoM drop; only 3 >\$1M incidents. Total \$18.18M across ~15 events.

A.8.1 Garden Finance — 2025-10-30 — ~\$11.4M

Solver-layer infra compromise (EY forensics: 4 suspicious IPs from Japan/China). Solver-intent architecture externalizes implicit risk to off-chain operators. ZachXBT disputed Garden’s “external solver” framing citing on-chain messages from a Garden deployer to the attacker.

- https://www.theregister.com/2025/10/31/attackers_dig_up_11m_in/
- <https://decrypt.co/356301/garden-finance-shares-forensic-findings-security-breach-limited-to-solver-layer>
- <https://protos.com/garden-hacker-begins-laundering-11m-loot-through-tornado-cash/>

A.8.2 Typus Finance (Sui) — 2025-10-15 — ~\$3.44M

Missing authorization assert in oracle `update_v2` — any caller could push arbitrary prices. Vulnerable module (deployed Nov 2024) was **out of scope** for the May 2025 MoveBit audit. TLP vault drained, bridged to Ethereum, converted to DAI. User wallets / SAFU / options vaults untouched. **Audit-scope $\neq$ deployed-scope.**

- <https://medium.com/@TypusFinance/typus-finance-tlp-oracle-exploit-post-mortem-report-response-plan-ce2d0800808b>
- <https://www.halborn.com/blog/post/explained-the-typus-finance-hack-october-2025>

A.8.3 Abracadabra Money (Cauldron V4) — 2025-10-04 — ~\$1.8M (1.79M MIM)

Third Cauldron exploit on the same codebase. `cook()` multi-action flow: Action 0 reset `CookStatus` after Action 5 (borrow) set `needsSolvencyCheck=true` → solvency check bypassed → under-collateralized borrows. Six addresses each drew ~300k MIM; proceeds → 395 ETH → 46 Tornado Cash deposits. **Systemic flaw: any lending/vault design accepting complex atomic action batches where solvency state toggles between steps.**

- <https://threesigma.xyz/blog/exploit/mimspell-abracadabra-hack-breakdown>
- <https://www.halborn.com/blog/post/explained-the-abracadabra-hack-october-2025>
- <https://www.quillaudits.com/blog/hack-analysis/abracadabra-hack-explained>

A.8.4 Non-attack curiosity: PYUSD (Paxos) — 2025-10-14

Accidentally minted ~\$300 trillion PYUSD via a botched internal transfer; tokens burned minutes later. Not an exploit, but a notable operational near-miss worth filing.

- <https://x.com/PeckShieldAlert/status/1984556692496138313>
-

A.9 Curator / governance postmortems (Morpho / Euler ecosystem)

- **Euler Labs:** Euler-DAO curated markets had **zero direct Stream exposure** per Euler’s statements. The \$137M “Euler” bad-debt figure sits in **third-party curator-operated vaults on Euler** (MEV Capital, Re7). Open governance thread: “Request for Formal Governance Proposal Regarding Compensation for Users Affected by the Elixir and Stream Labs Collapse” — <https://forum.euler.finance/t/request-for-a-formal-governance-proposal-regarding-compensation-for-users/1708>
- **MEV Capital (2025-11-06):** Disclosed ~\$25M exposure across Silo Avalanche USDC (\$7.2M) + BTC.b (164.3 BTC.b), Morpho Arbitrum USDC (\$628K), Euler Sonic USDC cluster (\$3.4M), Euler Sonic scUSD (\$7.02M). All 89–91.5% LLTV. Later total ~\$34M across four L2 permissionless markets + one vault. Claimed Midas/Upshift/Mellow mandates clean.

- <https://x.com/MEVCapital/status/1986038314642595857>
 - **Re7 Labs (2025-11-04 initial; December postmortem):** Initial “under 2% of TVL” later revised to **\$14.3–\$14.65M in isolated xUSD/USDT0 on Plasma + \$12.75M sdeUSD/deUSD across four Euler/Morpho markets**. Total >\$27M Stream + Elixir + Stable Labs. Community backlash over initial framing + subsequent \$13M Morpho fork on Berachain.
 - <https://x.com/Re7Labs/status/1985694621251387506>
 - <https://mpost.io/re7-labs-reports-impact-from-stablecoin-protocol-failures-total-losses-exceed-27m/>
 - **Gauntlet:** Clean on Stream. Challenged on Resolv: D2 Finance showed Gauntlet’s USDC Core vault held **\$4.95M in wstUSR/USDC = 98% of that market’s lender liquidity**. Gauntlet’s public framing: “limited exposure in a few high-yield vaults.”
 - <https://www.gauntlet.xyz/resources/market-report-liquidity-stress-period-nov-2025>
 - <https://thedefiant.io/news/hacks/defi-has-seen-resolv-s-usd25m-usr-exploit-many-times-before>
 - **Steakhouse Financial:** Reportedly **zero exposure** across mandates through Stream + Elixir. Positioning communicated via weekly “DeFi Market Update” on X.
 - <https://x.com/SteakhouseFi/status/1998751204491313178>
 - **TelosC:** Named as having allocated to xUSD; no detailed public postmortem surfaced in the sweep.
 - **Morpho forum:** No consolidated Stream/Resolv curator-delisting thread found. Bad-debt handling docs: <https://docs.morpho.org/curate/tutorials-v1/bad-debt/>
 - **Chorus One research:** “DeFi Curators in 2025” — curator-managed TVL ~\$1B → ~\$10B peak → ~\$6B Q4 2025, “directly linked to Stream.”
 - <https://chorus.one/reports-research/defi-curators-in-2025-navigating-chaos-building-resilience>
-

A.10 Analytical notes

- **No standalone Morpho Blue contract exploit in the window.** Morpho’s exposure was always second-order — curator allocations (Stream/xUSD, Elixir/deUSD, Resolv/USR, Kelp/rsETH) and market-listing/oracle governance. That is itself the finding. Lines up directly with the four “illusions” in **QFTaskList.tex** (collateral independence / TVL / diversification / leverage).

- **Best Morpho-risk case studies in the set:** Stream Finance (Nov 2025) — every pathology in one episode. Moonwell (Feb 2026) — cleanest oracle-wiring case. KelpDAO (Apr 2026) — cleanest looping-contagion case. Aevo Dec 2025 and YieldBlox Feb 2026 are clean oracle-config cases at smaller scale.
- **“Dark loops” thesis:** KelpDAO Apr 2026 + Stream Nov 2025 both show the pattern — single collateral/vault failure amplified by cross-lender looping produces a far larger TVL deletion than the face-value exploit.

B DeFi incidents — by drawer (Oct 2025 → Apr 2026)

Taxonomy view of the same incidents in `defi_incidents_2025-10_to_2026-04.md`. Each entry: date — name — amount — one-line cause. $\leftrightarrow$ marks cross-listed incidents (primary drawer + secondary tag). Short Morpho-relevance note at the end of each drawer.

B.1 1. Smart contract bugs (pure code / logic)

Arithmetic, reentrancy, state-consistency, soundness, unsanitized calls.

- **2026-04-13** — Hyperbridge — ~\$2.5M — Missing bounds check in MMR proof verifier $\rightarrow$ 1B bridged DOT minted. $\leftrightarrow$ bridge
- **2026-04-13** — Dango perps — \$410K (recovered) — Insurance-fund donation logic didn’t check `amount > 0`.
- **2026-04-03** — Silo Finance — \$392K — Oracle misconfig in a permissionless market. $\leftrightarrow$ oracle
- **2026-03-05/06** — 1inch Fusion v1 — ~\$5M — Calldata-length / buffer overflow in `_settleOrder`; end-user funds untouched.
- **2026-03** — Solv Protocol — ~\$2.7M — Reentrancy / double-mint in BRO vault handling ERC-3525 deposits; 135 BRO $\rightarrow$ 567M counterfeit BRO.
- **2026-02-26** — Foom Cash — \$2.26M (\$1.84M returned) — Groth16 verifier `delta2 == gamma2` (skipped Phase-2 trusted setup) $\rightarrow$ forged nullifier hashes.
- **2026-02-20/22** — Veil Cash — ~\$7K — Same `delta2 == gamma2` zkSNARK-soundness flaw (progenitor of Foom).
- **2026-01-25** — SwapNet — \$13.43M — Arbitrary-call + unsanitized `transferFrom` abused user approvals. $\leftrightarrow$ approval surface
- **2026-01-25** — Aperture Finance — \$3.67M — Same root cause as SwapNet. $\leftrightarrow$ approval surface
- **2026-01-21** — Saga (SagaEVM) — ~\$7M — Bridge-validation bypass via IBC precompile manipulation; \$D minted from thin air. $\leftrightarrow$ bridge
- **2026-01-08** — Truebit — ~\$26.44M — Integer overflow in legacy Solidity ^0.6.10 `getPurchasePrice()` (pre-SafeMath). **Archeological contracts.**
- **2026-01-05** — TMXTribe — \$1.4M — Unverified contract, no sanity checks in LP staking/swap loop.
- **2025-12-30** — Unleash Protocol — ~\$3.9M — Multisig governance takeover $\rightarrow$ malicious upgrade. $\leftrightarrow$ governance
- **2025-12-27** — Flow blockchain — ~\$3.9M — L1 execution-layer flaw $\rightarrow$ unauthorized FLOW + bridged-asset mint. $\leftrightarrow$ L1 infra
- **2025-12-04** — USPD stablecoin — ~\$1M — **Deployment-stage** CPIMP proxy takeover; shadow impl held admin silently 78 days.

- **2025-11-30** — Yearn Finance (yETH) — ~\$9M — “16 wei → infinite yETH” cached-virtual-balance desync.
- **2025-11-03** — Balancer V2 — ~\$120–128M — Rounding-direction inconsistency (`_upscaleArray` always rounds down) compounded via `batchSwap`.
- **2025-10-15** — Typus Finance (Sui) — ~\$3.44M — Missing authorization assert on oracle `update_v2`; out-of-scope of the audit. ↔ oracle
- **2025-10-04** — Abracadabra (Cauldron V4) — ~\$1.8M — `cook()` multi-action: Action 0 reset `CookStatus` after Action 5 set `needsSolvencyCheck=true` → solvency check bypassed.

Morpho relevance: Morpho Blue’s surface here is small (minimal, immutable core), but curator-added adapters/liquidator helpers and vault-wrapping tokens sit on this risk pane. The Abracadabra “multi-action composition bypass” pattern generalizes to any lender accepting atomic action batches.

B.2 2. Oracle failures (misconfig + manipulation)

- **2026-04-03** — Silo Finance — \$392K — Misconfigured feed on a permissionless market.
- **2026-03-16** — Venus Protocol — \$3.7M extracted / \$2.15M bad debt — Donation-attack bypassed supply cap + market-price oracle on thin THE.
- **2026-03-10** — Aave — \$27.78M liquidated (reimbursed) — CAPO rate-limit misconfig under-reported wstETH/ETH (1.19 vs 1.23).
- **2026-02-22** — YieldBlox (Stellar Blend) — \$10.2M (\$7.2M frozen) — Thin-liquidity Reflector oracle manipulation; single USTRY offer at 501 USDC.
- **2026-02-15** — Moonwell — \$1.78M bad debt — MIP-X43 wired cbETH/USD as cbETH/ETH only (no ETH/USD mult). **LST ratio-feed misconfig.**
- **2026-01-20** — MakinaFi — \$4.2M — Permissionless `updateTotalAum()` + no TWAP/circuit breaker + live Curve spot; flash-loan \$280M USDC, distort, lock NAV, withdraw.
- **2025-12-12** — Aevo / legacy Ribbon DOV — \$2.7M — Oracle upgrade accidentally let anyone push expiry prices.
- **2025-10-15** — Typus Finance — \$3.44M — Missing auth assert on `update_v2`.
- **2025-11-04** (secondary cause) — Stream Finance xUSD — Multiple lenders had **hardcoded xUSD oracle at \$1** to prevent cascade liquidations; locked the depeg in as bad debt. ↔ financial

Morpho relevance: This is the pane with the highest Morpho-ecosystem tail risk. Every curator-listed LST/LRT/synthetic-stable market rides an oracle decision; Moonwell/Aave CAPO/MakinaFi/Aevo are all reproducible in MetaMorpho vaults via a single bad parameter. **Hardcoded \$1 oracles on depegging collateral is the specific anti-pattern the user’s `QFTaskList.tex` needs to flag.**

B.3 3. Bridge / cross-chain validation

- **2026-04-18** — KelpDAO (rsETH) — ~\$292M — Single-verifier LayerZero DVN (1-of-1) → forged cross-chain msg → 116,500 rsETH minted → looped through Aave/Morpho/Fluid. **Cross-lender contagion.**
- **2026-04-13** — Hyperbridge — ~\$2.5M — MMR proof-verifier bug; 1B bridged DOT minted on Ethereum.
- **2026-02-21** — IoTeX ioTube — ~\$4.3M + 111M CIOTX minted — Compromised Ethereum-side Validator key. ↔ credential
- **2026-01-31** → **02-01** — CrossCurve — ~\$3M — Spoofed Axelar messages via unvalidated **expressExecute** in PortalV2.
- **2026-01-21** — Saga (SagaEVM) — ~\$7M — IBC precompile manipulation minted \$D.

Morpho relevance: Morpho doesn't run a bridge, but collateral that traveled over a bridge can introduce an exogenous mint-event risk the lender inherits. KelpDAO is the canonical case — a vault lending against rsETH is exposed to the rsETH bridge regardless of the lender's own correctness.

B.4 4. Credential / key compromise

- **2026-04-14** — Zerion — ~\$100K — UNC1069 AI-assisted SE; hot-wallet drain.
- **2026-02-21** — IoTeX Validator — see bridge drawer.
- **2026-01-31 (disclosed)** — Step Finance — ~\$27.3M (261,854 SOL) — Exec device phished; keys drained multisig.
- **2025-11-20** — GANA Payment — ~\$3.1M — Smart-contract ownership compromised; reward rates changed + unstake drain.
- **2025-10-30** — Garden Finance — ~\$11.4M — Solver-layer infra compromise (EY: IPs from Japan/China).
- **2026-03-22** — Resolv Labs — \$25M ETH + 80M unbacked USR — Compromised SERVICE_ROLE EOA (not multisig) + missing mint-cap/oracle checks. ↔ contract bug

Morpho relevance: Off-chain hygiene of every participant in a Morpho vault's dependency graph (curator signing keys, collateral issuer admin keys, oracle updater keys) is in scope. Resolv is the painful case where a stablecoin-issuer EOA compromise cascaded into Morpho vault bad debt.

B.5 5. Governance / multisig compromise (via social engineering)

- **2026-04-01** — Drift Protocol — ~\$285M — Lazarus SE'd Security Council into pre-signing txs wrapped as Solana durable nonces; activated months later to list fake CVT as collateral.

- **2025-12-30** — Unleash Protocol — \$3.9M — Multisig governance takeover → unauthorized upgrade. ↔ contract bug

Morpho relevance: Curator governance is the Morpho analog. A sufficiently patient SE campaign against a curator’s signers could reproduce Drift-style “new collateral listed, caps raised, then drained.” User’s existing “Étude villain / attack Morpho” thread maps directly here.

B.6 6. Frontend / DNS / supply-chain

Protocol contracts untouched; losses come through user-side approvals or wallet key theft.

- **2026-04-14** — CoW Swap (cow.fi) — ~\$1.2M — Forged IDs against Finland Traficom + Gandi → DNS points to phishing.
- **2026-03-19** — Neutrl — ~zero — .fi DNS-campaign hijack attempt.
- **2026-02-16** — OpenEden — no loss — AngelFerno DNS hijack.
- **2026-02-16** — Curvance — zero — AngelFerno DNS without DNSSEC; detected pre-drain.
- **2025-12 (exact day unclear)** — Trust Wallet extension v2.68 — >\$6M — Malicious extension version exfiltrated keys.
- **2025-11-21/22** — Aerodrome + Velodrome — ~\$700K–\$1M+ — NameSilo internal compromise bypassed 3DNS multisig; DNSSEC removed.

Morpho relevance: Not a direct Morpho attack surface, but the user-approval model of any DeFi lender means a DNS hijack of a popular vault aggregator frontend (Morpho.org itself, or any MetaMorpho allocator’s UI) would produce Aerodrome-style losses without touching Morpho contracts.

B.7 7. Financial / off-chain loss / stablecoin depeg

Not a contract bug — exposure via assets losing peg, off-chain fund-manager losses, recursive collateral loops.

- **2026-03-22** — Resolv Labs USR depeg — (see credential drawer; the depeg itself is the financial contagion arm) — Hit ~15 Morpho vaults; Gauntlet USDC Core held \$4.95M in wstUSR/USDC = 98% of that market’s lender liquidity.
- **2025-11-04 → 11-07** — Stables Labs USDX — -94% — Triggered by Balancer V2 drain of USDX/sUSDX pool + cascading leveraged liquidations on Lista/PancakeSwap.
- **2025-11-04 → 11-07** — Elixir deUSD — -98% — 65% of deUSD collateral was in private Morpho vaults where Stream was sole borrower using xUSD. Collapsed with Stream.

- **2025-11-04 — Stream Finance (xUSD)** — \$93M initial / ~\$285M interconnected — Off-chain fund-manager loss. Hardcoded \$1 oracles locked bad debt into books. Euler third-party curator vaults: \$137M. TelosC (\$123.6M) and Elixir (\$68M) largest single exposures. **The canonical case: pinned oracles + risk-curator allocation + hidden-borrower private vaults + recursive loops + TVL illusion all in one episode.**

Morpho relevance: This is the most important drawer for the user’s thesis. Every “illusion” in their `QFTaskList.tex` (collateral independence, TVL, diversification, leverage) shows up here. **Stream is the single best case study in the whole list.**

B.8 8. Market manipulation (perps / thin pools)

- **2025-11-13** — Hyperliquid HLP — \$4.9M bad debt — \$20M POPCAT buy-wall at \$0.21, withdrawn, crashed; community vault absorbed bad debt. **Third such attack on Hyperliquid in 2025.**
- **2026-04-15 → 04-17** — Rhea Finance (NEAR) — \$18.4M — Fake pools on Ref Finance + Rhea margin feature → borrow real vs phantom collateral. (Also: oracle-adjacent.)

Morpho relevance: Morpho Blue itself is slow-moving (no perps), but its permissionless market creation means a curator who lists a thin collateral with a market-price oracle reproduces the Venus/Rhea pattern. Supply-cap controls matter here.

B.9 9. L1 / chain-level

- **2025-12-27** — Flow — \$3.9M — Execution-layer bug allowed native FLOW + bridged-asset mint. Foundation proposed 6h chain rollback.

Morpho relevance: Any chain Morpho deploys to inherits this risk level as a baseline. Worth flagging to curators the historical base rate of L1 incidents per chain.

B.10 10. Operational near-misses / non-exploits

- **2025-10-14** — PYUSD (Paxos) — accidentally minted ~\$300 trillion then burned minutes later. Not an exploit. Worth filing as an operational base-rate signal for issuer mistakes.
 - **2026-04-15** — Grinex exchange — \$13.7M — Sanctioned CeFi venue drain; not DeFi but adjacent in the April narrative.
-

B.11 Drawer sizes (period total)

Drawer	# incidents	Order-of-magnitude \$
Smart contract bugs	19	~\$200M (Balancer dominates)
Oracle failures	9 (overlapping)	~\$50M directly + \$285M contagion enabled
Bridge / cross-chain	5	~\$310M (Kelp dominates)
Credential / key comp.	6	~\$70M
Governance / multisig	2	~\$290M (Drift dominates)
Frontend / DNS	6	~\$8M
Financial / depeg	3	~\$450M interconnected
Market manipulation	2	~\$23M
L1 / chain-level	1	\$3.9M
Op. near-miss	2	negligible

(Dollar totals approximate and sometimes double-count — Kelp is in both “bridge” and drives the “financial contagion” around it. This is the point — the drawers overlap precisely where systemic risk lives.)

B.12 Cross-drawer patterns worth pulling out

1. **DPRK / Lazarus attribution on the big ones** — Drift (\$285M), KelpDAO-related (\$292M operational attribution debated), Zerion (\$100K), Upbit CeFi (\$36M Nov 2025). The pattern: increasingly patient, AI-assisted SE against signers rather than direct contract attacks.
2. **Archeological contracts** — Truebit (2021 code), Aevo legacy Ribbon, Yearn iEarn v1. Forks and legacy deployments carry tail risk for years.
3. **.fi / DNS-registrar weakness as a campaign** — CoW Swap + Steakhouse + HypurrFi + NeutrL. Registrar hardening (RegistryLock, DNSSEC) is the cheap mitigation.
4. **Curator concentration > diversity** — Stream, Resolv, Elixir all show that “vault N has exposure to asset X” aggregated across curators produces concentrated single-asset risk even when any individual vault looks small. Directly validates the **TVL illusion** and **diversification illusion** entries in `QFTaskList.tex`.
5. **Oracle-pinning as a cascade amplifier** — Hardcoding \$1 on a depegging asset converts a price-discovery event into unrecoverable bad debt. Stream is the textbook case.